Activity: "Stop the Smart Home Breach"

Objective: Identify prevention, and detection methods in a real-world IoT-to-corporate attack scenario

Instructions:

1. **Review** the attack scenario below:

   HomeTech Corp's CEO, Alex Chen, has a "SmartHome Pro" thermostat connected to home Wi-Fi. Alex works from home using a personal laptop (BYOD) that connects to the corporate network via VPN. The thermostat was never properly configured after installation.

   Attack Timeline:

   - **Day 1:** Attacker scans internet for vulnerable SmartHome Pro thermostats
   - **Day 2:** Attacker exploits default credentials on Alex's thermostat
   - **Day 3:** From thermostat, attacker performs ARP poisoning on home network
   - **Day 4:** Attacker captures VPN credentials from Alex's laptop
   - **Day 5:** Attacker accesses corporate network, targets financial systems

2. **Complete the table** below by:
   - Brainstorming **How to Prevent It**
   - Brainstorming **How to Detect It**

Step	What the Hacker Does	Vulnerability Exploited	How to Prevent It	How to Detect It
1	Attacker scans internet for vulnerable Smart Home Pro thermostats	Exposed IoT devices with insufficient network hardening	1. Create ACL that blocks access to IOT devices 2. Network segmentation placing all IoT devices in separate VLANs from the laptop. 3. NAC controls that apply to all devices on local network. 4. If device supports Bluetooth low energy to utilize 128-bit AES encryption. 5. Adopt EDR security solution to detect malicious actions or connections on the network. 6. Keeping up to date on patchworks and firmware on the iot device. 7. Disable unnecessary ports	Use Firewall IDS/ IPS combined with Cloud threat intelligence on the corporate side. Keep an eye for any connection related attempt on thermostat's IP address. If thermostat would not change its IP address due to constant connection DHCP lease will keep renewing. Watch for outbound traffic from Thermostat. Based on device profiling, look for misbehavior (log review). Verify whether the thermostat (or home router) is even reachable from the internet. Check if it has default IP address. Surface level pen test for IOT devices. • Use external scanning tools (like Shodan-style searches or your own scans) to see if any ports/services are exposed. - Monitor router/firewall logs for inbound scans

2	Attacker exploits default credentials on Alex's thermostat	Default password configuration	1. Credential hardening – Set strong password policy and change default passwords. 2. Enable Multifactor Authentication (MFA) for IOT management if available. 3. Register all devices to FortiGate and flag/isolate non-compliant devices. **4.** Restrict access to thermostats interface.	Monitor unusual network traffic from suspicious IP. - Use the router/firewall to detect **inbound connection attempts** to the device - DNS logging and alerting
3	From thermostat, attacker performs ARP poisoning on home network	Unsecured local network and lack of ARP protection	Set up guest network to segment the network to prevent lateral movement Static DHCP – MAC ADDR filtering EDR/End point detection software Update router firmware Change default passwords on router and IoT devices (thermostat) Disable WPS on router and IoT devices (susceptible to brute force attacks)	ARP poisoning often causes visible symptoms: • Internet suddenly becomes slow or unstable • Frequent disconnections on Wi-Fi • Browser shows **"connection not private"** warnings on normal sites • Smart devices (like thermostat) behaving oddly

				ARP anomaly detection, Suricata /snort - Install host-based detection: - Tools or EDR should flag: - **ARP table changes** for the default gateway - Duplicate ARP responses -
4	Attacker captures VPN credentials from Alex's laptop	Insecure credential handling and transport	• Best approach is, not to store sensitive info like credentials in laptop and have them by heart. If not, store the credentials in a password manager (third party solution) which encrypt and save securely those values. • One other approach is to separate day-to-day Alex user from root and secure root or make access to VPN using MFA access. (Principle of least privilege) • Probably full disk encryption also makes the credential abuse more difficult.	Detect suspicious VPN authentication patterns: • Logins from unusual IPs / geolocations • Multiple failed attempts followed by a success • Logins at unusual times for Alex - Enforce and monitor MFA anomalies - Endpoint detection for credential access

			• Use more secure protocol for VPN (SSL VPN, or ZTNA) • Being aware and alert system of Abnormal behavior or unauthorised access in Alex laptop.	Keylogging like behaviour - Network traffic inspection - Using Nmap utility to check open ports
5	Attacker accesses corporate network, targets financial systems	Insufficient access controls and network segmentation in corporate environment	Encrypt Files - BitLocker RBAC – PIM, PAM, JIT Access only authorized finance staff can access financial records Endpoint Trust Compliance – Intune Restrict and Monitor Access to Financial Systems. Deploy EDR (Defender XDR) DLP – To prevent sensitive data exfiltration, block unauthorized export or transfer of financial records. Zero trust network access - MFA Windows Hello, Screen Lock, Pin Network Segmentation – VPN Segmentation	Intrusion Detection Systems alarms NG Firewall and SIEM logs: unusual time, geolocation, “traffic destinations” Abnormal user and database activity, large data transfers going out of network

			FortiGate - To prevent the attacker from going further inside the attacker. we can prevent by locking down sensitive systems like financial using the FortiGate as it acts like security guard and blocks unauthorized access. FortiToken - Adding extra verification gives a good defense against the attacker. FortiClient - And never trusting every device. since Alex is using BYOD laptop. It's best to use company laptop rather than personal. Using this, we can regular checks if the device is safe before allowing access. FortiAnalyzer - it helps to watch for any suspicious activity like accessing into financial systems. by using this we can track activity.	